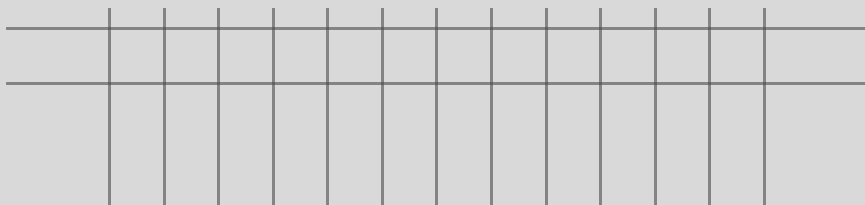


SECURITY ANALYST

PROJECT

QUSAY AL-HEMIRY



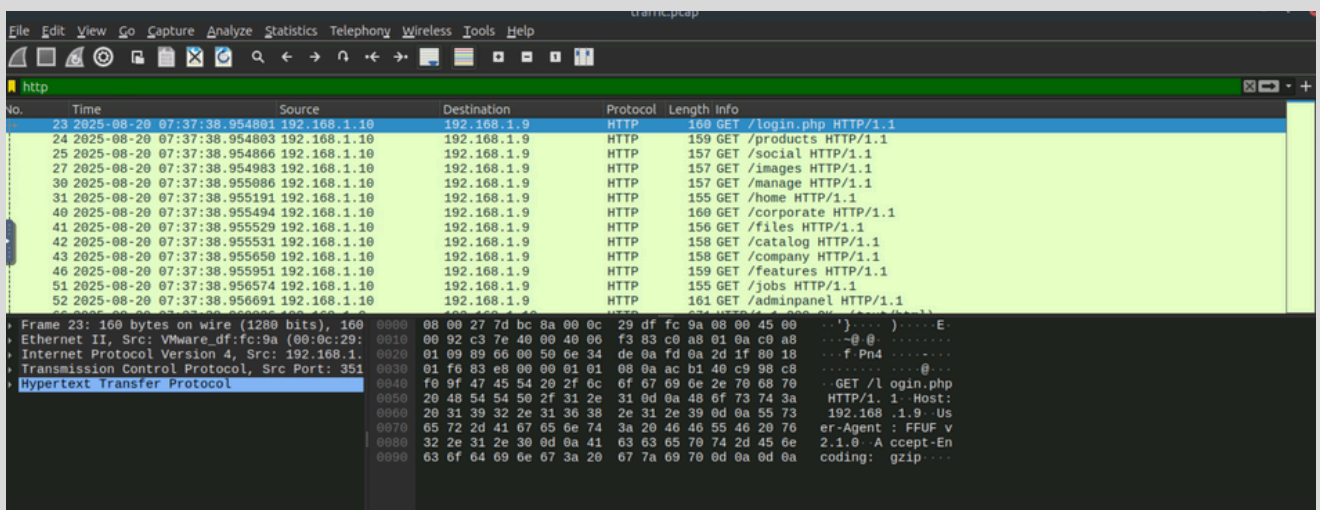
PORTFOLIO

Web Log Analysis: Detecting Brute-Force & SQL Injection Attacks in a Banking Environment - Tryhackme:

Scenario Overview:

As part of a simulated incident for a banking environment, the security team provided me with an Apache access log file for analysis. The team suspected unauthorized activity targeting the bank's web application. My task was to investigate the log entries, identify any malicious patterns, and determine whether the attacker successfully accessed the system.

Tools used:wireshark



After reviewing the log file, I identified two clear indicators of malicious activity:

1. Brute-Force Login Attempts

A large number of repeated POST /login.php and GET /login.php requests were observed within the same second.

These requests originated from the same IP address and used the user-agent: **FFUF v2.1.0**

This confirms the use of Hydra, a well-known brute-force tool used to automate password guessing

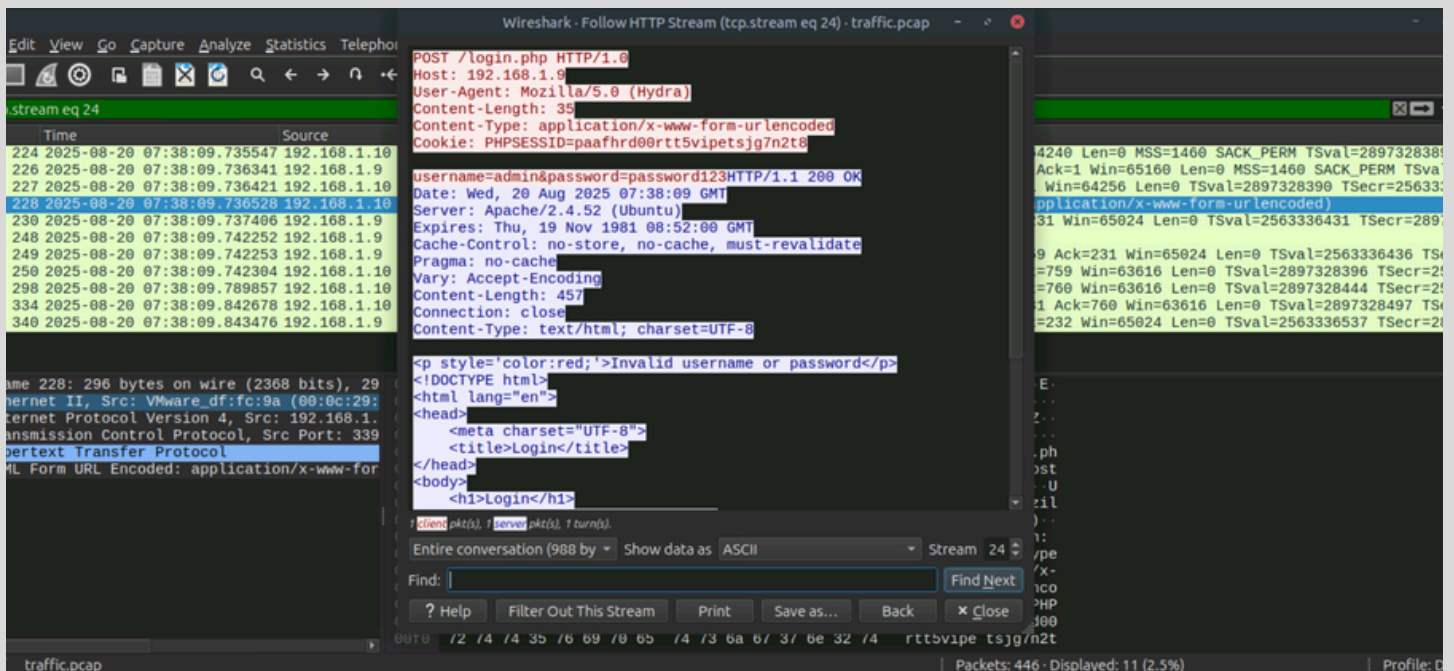


IMAGE FROM HTTP STREAM

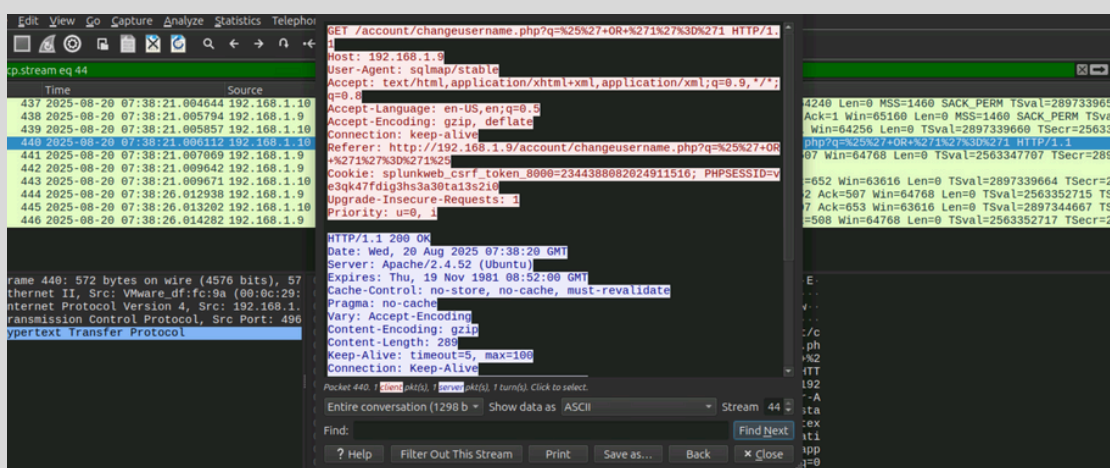
After analyzing the sequence of events, I examined the packet details to gather deeper evidence of the attack.

During the brute-force phase, the repeated POST /login.php requests allowed me to identify the exact credentials the attacker used. By inspecting the final request (packet 13), which was successfully authenticated, it became clear that the attacker discovered the valid password:

password123

This weak password provided unauthorized access to the account—an especially critical issue since it belonged to an admin user

2. SQL Injection Attempt:



At the end of the log file, I identified a suspicious request targeting: **/account/changeusername.php**

with the parameter: **% ' OR '1'='1**

This is a classic SQL Injection payload designed to bypass authentication or manipulate database queries

The server responded with:

- 200 312
- 200 262

These numbers represent the response size (bytes) and indicate that the server returned a normal page, however, they do not indicate a successful login or SQL injection they simply show that the server processed the request and returned standard output.

There is no evidence of unusual data, redirects, or access to internal authenticated areas